

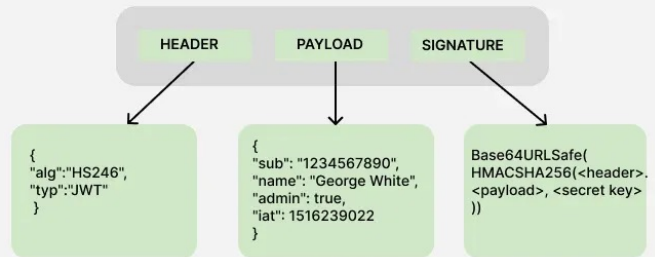
JSON Web Token (JWT)

- compact, **digitally signed token** used for **authentication** and **authorization** in web applications
- allows servers to verify users **without storing session data** (stateless authentication).

Parts of JWT (3 Parts)

- 1 Header** - Contains algorithm (e.g., HS256, RS256)
- 2 Payload** - Contains claims (user data)
- 3 Signature** - Created using:
`Sign(header + payload, secret/private_key)`
 - Prevents tampering.

Structure of a JSON Web Token (JWT)



How JWT Works (Flow)

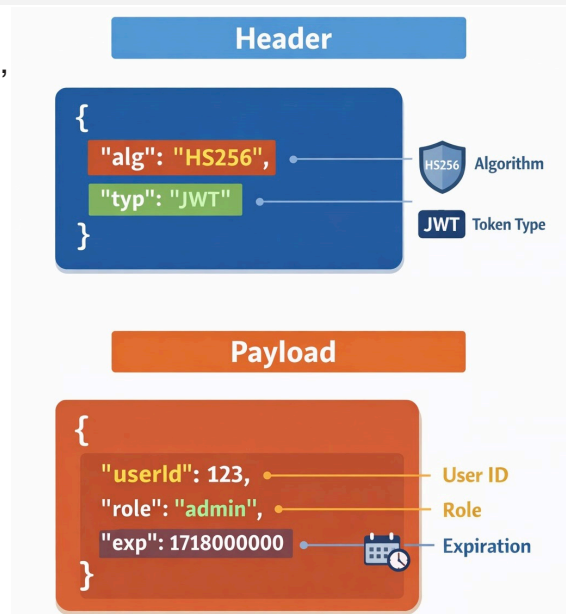
- User **logs in**.
- Server **verifies** credentials.
- Server **creates & signs JWT**. (Payload - encoded, not encrypted)
- Client **stores** token in cookies.
- Client **sends token** in Authorization: **Bearer <token> header**.
- Server **verifies**:
 - Signature
 - Expiry (exp)
 - Validity
- If **valid** → request **allowed**
- If **invalid** → **401 Unauthorized**

Case 1: Hacker changes payload/header only

- Signature** remains **old**.
- Server **recalculates** signature.
- Signatures **don't match**.
- ❌ Request rejected (401).
- Reason: Signature is tied to header - payload.
- Any change breaks it.

Case 2: Hacker changes payload/ header + signature

- Without secret/private key:
 - Hacker **cannot generate valid signature**.
 - ❌ Request rejected.



JSON Web Token

